

THREAT REPORT: AI-DRIVEN EXPLOITATION AT SCALE LEVERAGING CVE-2026-82078

Visual Summary



Summary

The observed cluster of activity exploits the public-facing vulnerability CVE-2026-82078. The campaign employs a broad set of credential-access, discovery, and execution techniques, though specific malware families and targets have not been identified. No country or sector has been confirmed as a victim. Priority should be given to alerting on new local or domain account creation (Event ID 4720/4728) and enforcing an approval workflow for account provisioning, while patching CVE-2026-82078 on all affected systems.

Threat Overview

The threat actor is not identified in the source. Malware families were not identified. The campaign leverages the central vulnerability CVE-2026-82078 to gain initial foothold. Victimology, including targeted countries or sectors, is not disclosed.

Attack Chain and Priority Control

The observed techniques follow a typical post-exploitation progression: exploitation of a public-facing application (T1190) → lateral movement via SMB/Windows admin shares (T1021.002) → credential dumping from SAM, LSA, and cached domain credentials (T1003.) → *extensive account and group discovery (T1087., T1069.)* → *file and directory discovery (T1083) and credential harvesting from files (T1552.001)*. *The chokepoint identified by the analyst is T1136.002 Domain Account**.

Priority control: *Alert on new local/domain account creation (Event ID 4720/4728); enforce approval workflow for account provisioning. In parallel, patch CVE-2026-82078 on all affected systems.*

Infrastructure and Corroboration

Enrichment data did not reveal any hosting providers or autonomous system numbers associated with the malicious infrastructure. Abuse.ch reported no corroborated malware families, and AbuseIPDB flagged zero indicators with confidence above 80 % (highest confidence observed 0 %).

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1059.007 JavaScript
- T1003.002 Security Account Manager
- T1003.004 LSA Secrets
- T1087.002 Domain Account
- T1087.001 Local Account
- T1069.002 Domain Groups
- T1190 Exploit Public-Facing Application
- T1021.002 SMB/Windows Admin Shares
- T1136.001 Local Account
- T1003.005 Cached Domain Credentials
- T1136.002 Domain Account
- T1482 Domain Trust Discovery
- T1083 File and Directory Discovery
- T1552.001 Credentials In Files
- T1059.001 PowerShell
- T1069.001 Local Groups
- T1059.003 Windows Command Shell
- T1071.001 Web Protocols
- T1018 Remote System Discovery
- T1090.001 Internal Proxy

Analytical Scores

- Priority technique (graph chokepoint): T1136.002 Domain Account (centrality 0.3037).
- Operational risk: High (score 0.636, reaches command-and-control).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4296; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Fox Kitten	0.4296
FIN13	0.4288
Leafminer	0.4006
Ke3chang	0.3977
Orangeworm	0.3714

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
Hash	08387ff35cc7854ddea1e2106b1150e9fe80646541c95c5a7121b77c9bc0228e
Hash	092788c6598784d91b411dde40f274c73448f6c803f57c8d0ca85a22d0516e19
Hash	243de5404091bcd920041cf2f4dd22e80f2c2922022854991d2b5e0ac78f2fee
Hash	4cd2a9d574febb1545966561d598c57194da47b09f9175dd888e6aa5d267f91c
Hash	5cc0eee4a1d8dbb737838e25f1e9ae37170a54ae757c431b5d6422904538bde3
Hash	6106fa15dc10764114d039f26a96d793c559f04b080a27af9f2f27c2eeb391e0

Type	Indicator
Hash	6b5c50c2f88861943426b054fe3ff42f59ffd29d3dcf3cb1bb6c785b12077ee3
Hash	844d80da0d8690586f156e1793cde12b5e93a24540e511d4ddb71489cf5a8796
Hash	b1adeecb0f2df0d66298a4f3f9a866ddf4c83731892a13ec9b97d405fd50d7b9
Hash	b3d73d0a9d26bde03be3511e7293bf67c907fb00d5b6bb8c189a8f37b15987fe
Hash	ca996a2dea2529a1e94d7db141259f4fc700b9ab30da36d8b479b81a9b90973b
Hash	eb4a6a99019f5c5e35f5f3a86867ad65ff1e7338d4937544313b448172988f86
Hash	f03e9c6b1923556269004db628e23d373e11224304e136612a61b1e7ae1b7f1f
Hash	f5eebbce3769c8880646c6e8c26d86fbd00e21e193024295641d82c40822adcf

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1136.002 Domain Account (persistence)
- **Observed here:** T1136.002 Domain Account was the only persistence technique observed in this campaign, so the pivot is projected from cross-actor behaviour.
- **Projected pivot:** T1098 Account Manipulation (persistence)
- **Basis:** of the 13+ groups that use Domain Account, this pairing runs 5.6x above base rate, a disproportionately-coupled move rather than the obvious one.

If the actor's attempt to create a new domain account (T1136.002) is blocked, they could pivot by manipulating existing accounts—adding them to high-privilege groups, modifying group memberships, or altering account attributes—to achieve comparable privileges (T1098). Defenders should alert on privilege/group changes and credential additions to accounts (Event ID 4738/4670); review conditional-access changes.

Also plausible (same tactic): T1505 Server Software Component (n=12, lift 2.9), T1133 External Remote Services (n=10, lift 2.8)

Detection and hardening for the pivot (T1098 Account Manipulation)

- **Telemetry:** Windows Security (account management); Azure AD audit logs
- **Detect:**
 - Security 4728/4732/4756 (added to security-enabled groups), 4738 (account changed), 4670 (permissions changed)
 - New credentials/keys added to accounts or app registrations in the IdP

- MFA method added or reset outside a normal workflow
- **Harden:**
 - Alert on privileged-group changes; approval workflow for role grants
 - Monitor and restrict service-principal credential additions
- **MITRE:** M1032 Multi-factor Authentication, M1026 Privileged Account Management, M1018 User Account Management · DS0002 User Account, DS0026 Active Directory

